

USING NIST FOR SECURITY AND RISK ASSESSMENT



Tom Dover
Butler County Community College

Butler County Community College
Using NIST for Security and Risk Assessment

Tom Dover

This text is disseminated via the Open Education Resource (OER) LibreTexts Project (<https://LibreTexts.org>) and like the thousands of other texts available within this powerful platform, it is freely available for reading, printing, and "consuming."

The LibreTexts mission is to bring together students, faculty, and scholars in a collaborative effort to provide an accessible, and comprehensive platform that empowers our community to develop, curate, adapt, and adopt openly licensed resources and technologies; through these efforts we can reduce the financial burden born from traditional educational resource costs, ensuring education is more accessible for students and communities worldwide.

Most, but not all, pages in the library have licenses that may allow individuals to make changes, save, and print this book. Carefully consult the applicable license(s) before pursuing such effects. Instructors can adopt existing LibreTexts texts or Remix them to quickly build course-specific resources to meet the needs of their students. Unlike traditional textbooks, LibreTexts' web based origins allow powerful integration of advanced features and new technologies to support learning.



LibreTexts is the adaptable, user-friendly non-profit open education resource platform that educators trust for creating, customizing, and sharing accessible, interactive textbooks, adaptive homework, and ancillary materials. We collaborate with individuals and organizations to champion open education initiatives, support institutional publishing programs, drive curriculum development projects, and more.

The LibreTexts libraries are Powered by [NICE CXone Expert](#) and was supported by the Department of Education Open Textbook Pilot Project, the California Education Learning Lab, the UC Davis Office of the Provost, the UC Davis Library, the California State University Affordable Learning Solutions Program, and Merlot. This material is based upon work supported by the National Science Foundation under Grant No. 1246120, 1525057, and 1413739.

Any opinions, findings, and conclusions or recommendations expressed in this material are those of the author(s) and do not necessarily reflect the views of the National Science Foundation nor the US Department of Education.

Have questions or comments? For information about adoptions or adaptations contact info@LibreTexts.org or visit our main website at <https://LibreTexts.org>.

The LibreTexts name, logo, and book covers are trademarked by LibreTexts, Inc. (a 501(c)(3) not-for-profit organization) and protected against unauthorized use.

This text was compiled on 07/15/2026

- [InfoPage](#) by [Delmar Larsen](#) is licensed [Public Domain](#).

TABLE OF CONTENTS

Book Information

Licensing

Author's Note

Preface

Scope

Target Audience

Prerequisites

Acknowledgements

Keywords

1: Introduction

- 1.1: The Distributed Challenge of Security and Risk Assessment
- 1.2: Why use NIST?
- 1.3: Regulatory and Legal Issues
- 1.4: FISMA
- 1.5: FIPS 199 and 200
- 1.6: Security Assessment Versus Risk Assessment- What's the Difference?

2: Security Assessment Using SP.800-171r2 and SP.800-172

- 2.1: Introduction
- 2.2: Process
- 2.3: Methodology
- 2.4: Design
- 2.5: Variables
- 2.6: Using the Assessment Workbook

3: Security Assessment using SP.800-213 and SP.800-213A

- 3.1: Introduction
- 3.2: Governance and Oversight
- 3.3: Challenges to Assessing IoT-MIoT
- 3.4: Using NIST SP.800-213A Capabilities for MIoT Security Assessment
- 3.5: Evaluation Process
- 3.6: Methodology - Design and Variables
- 3.7: Using the Assessment Workbook
- 3.8: Advantages and Benefits of Using NIST SP.800-213 and SP.800-213A for MIoT Assessment

4: VI. Assessment Workbook Downloads

[References](#)

[APPENDIX A: Assessing Enhanced Security](#)

[APPENDIX B: Adversary Effects](#)

[Index](#)

[Glossary](#)

[About the Author](#)

[Detailed Licensing](#)

Book Information

TITLE

Using NIST for Security and Risk Assessment

SHORT TITLE

Using NIST Special Publications (SP) 171r2/172 and 213/213A for Security & Risk Assessment

SUBTITLE

Protecting Controlled Unclassified Information (CUI) in Information and Operation Technology Systems

SHORT DESCRIPTION

A practical approach for applying NIST Special Publications (SP) guidance to Information (IT) and Operational (OT) technology systems. Methodology includes assessing and evaluating the security of systems containing Confidential but Unclassified Information (CUI).

AUTHOR(S)

Thomas P. Dover

thomas.dover@bc3.edu

PUBLICATION DATE

07/10/2022

COPYRIGHT

Copyright 2022. Thomas P. Dover

(2nd Edition)

OER LICENSE

CC-BY-NC (Creative Commons, Attribution, NonCommercial)

BOOK TAGLINE

Applying NIST Guidance to Cybersecurity Assessment

PRIMARY SUBJECT

Computer Security

ADDITIONAL SUBJECTS

Risk Assessment, Information Technology Industries, Network Security, Computer Science

LONG DESCRIPTION (Abstract)

This book describes how NIST Special Publications (SP) 800-171r2 (*Protecting Controlled but Unclassified Information in Nonfederal Systems and Organizations*), SP.800-172 (*Enhanced Security Requirements for Protecting Controlled Unclassified Information*) and SP.800-172A (*Assessing Enhanced Security Requirements for Controlled Unclassified Information*) can be used to evaluate the cybersecurity posture of Information (IT) or Operation Technology (OT) systems and supporting frameworks. It will demonstrate that baseline security requirements outlined in SP.800-171r2 and SP.800-172/172A for the protection of Controlled Unclassified Information (CUI) can be applied to any information system requiring data protection.

It further presents the application of SP.800-213 (*IoT Device Cybersecurity Guidance for the Federal Government: Establishing IoT Device Cybersecurity Requirements*) and SP.800-213A (*IoT Device Cybersecurity Guidance for the Federal Government: Establishing IoT Device Cybersecurity Requirement Catalog*) to OT system assessment in order to determine relative compliance with recommended standards. This approach allows organizations to evaluate the level of risk an IoT device poses to information systems. It also reviews the current state of IoT cybersecurity and privacy protection using historical and current industry guidance & best-practices; recommendations by federal agencies; NIST publications; Executive Orders (EO) and federal law. Similarities and differences between IoT devices and “traditional” (or classic) Information Technology (IT) hardware will be offered along with challenges IoT poses to cybersecurity and privacy protection.

An explanation of how these NIST publications align with information security and how this alignment suffices for evaluating an IT environment security will be given along with the process and procedure for performing such evaluation.